CRA-related standards

Status from 3 February

OpenSSF

OPEN SOURCE SECURITY FOUNDATION

Copyright © 2024 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.

Agenda

- Public inquiry phase for CRA-related standards
- Events
- Complementary standards
- Have your say
- AOB
- PT3 review
- Back-up slides

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Public inquiry phase for CRA-related standards

CRA Work Items

CRA	M/606 ID	Venue	Work Item	Standard reference	Standard title
		CEN-CLC/JTC 13 WG 9	JT013095	EN 40000-1-1	Cybersecurity requirements for products with digital elements – Vocabulary
I.I	2 to 14	CEN-CLC/JTC 13 WG 9 PT1	JT013089	EN 40000-1-2:2025	Cybersecurity requirements for products with digital elements – Principles for cyber resilience
I.II	2 to 14	CEN-CLC/JTC 13 WG 9 PT3	JT013090	EN 40000-1-3	Cybersecurity requirements for products with digital elements – Vulnerability Handling
	2 to 14	CEN-CLC/JTC 13 WG 9 PT2	JT013091	EN 40000-1-4	Cybersecurity requirements for products with digital elements – Generic Security Requirements
	2 to 14	CEN-CLC/JTC 13 WG 9	JT013097	TR 40000-1-5	Cybersecurity requirements for products with digital elements – Threats and Security Objectives
	2 to 14	CEN-CLC/JTC 13 WG 6	JT0130XX	TS TTTTTTT	Guidance for the application of EN 18037 in support of the CRA
	2 to 14	CEN-CLC/JTC 13 WG 6	JT0130XX	TR TTTTTT	Documentation of the EN 18037 assessment results for the Consumer IoT market sector
III.I.1	16	CEN/TC 224 WG 17		EN TTTTTTT	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers : criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)
III.I.2	17	ETSI CYBER-EUSR	DEN/CYBER-EUS-006	EN 304 617	Essential cybersecurity requirements for browsers
III.I.3	18	ETSI CYBER-EUSR	DEN/CYBER-EUS-007	EN 304 618	Essential cybersecurity requirements for password managers
III.I.4	19	ETSI CYBER-EUSR	DEN/CYBER-EUS-0018	EN 304 619	Essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software
III.I.5	20a	ETSI CYBER-EUSR	DEN/CYBER-EUS-005	EN 304 620	Essential cybersecurity requirements for virtual private networks (VPNs)
III.I.5	20b	CLC/TC 65X WG 3	81652	EN 62443-5-XX	Security Profile for products with digital elements with the function of virtual private network (VPN)
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	79830	EN IEC 62443-3-3:2019	Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	81487	EN IEC 62443-4-1:2018	Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	79973	EN IEC 62443-4-2:2019	Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components
III.I.6	21a	ETSI CYBER-EUSR	DEN/CYBER-EUS-009	EN 304 621	Essential cybersecurity requirements for network management systems
III.I.6	21b	CLC/TC 65X WG 3	81650	EN 62443-5-XX	Security Profile for network management systems (based on IEC 62443)
III.I.7	22a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0010	EN 304 622	Essential cybersecurity requirements for Security information and event management (SIEM) systems
III.I.7	22b	CLC/TC 65X WG 3	81654	EN 62443-5-XX	Security Profile for security information and event management (SIEM) systems (based on IEC 62443)
III.I.8	23	ETSI CYBER-EUSR	DEN/CYBER-EUS-008	EN 304 623	Essential cybersecurity requirements for boot managers

CRA Work Items

CRA	M/606 ID	Venue	Work Item	Standard reference	Standard title
III.I.9	24	ETSI CYBER-EUSR	DEN/CYBER-EUS-0015	EN 304 624	Essential cybersecurity requirements for public key infrastructure and digital certificate issuance software
III.I.10	25a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0017	EN 304 625	Essential cybersecurity requirements for physical and virtual network interfaces
III.I.10	25b	CLC/TC 65X WG 3	81651	EN 62443-5	Security Profile for physical and virtual network interfaces (based on IEC 62443)
III.I.11	26	ETSI CYBER-EUSR	DEN/CYBER-EUS-0012	EN 304 626	Essential cybersecurity requirements for operating systems
III.I.12	27a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0013	EN 304 627	Essential cybersecurity requirements for routers, modems intended for the connection to the internet, and switches
III.I.12	27b	CLC/TC 65X WG 3	81653	EN 62443-5	Security Profile for routers, modems intended for the connection to the internet, and switches (based on IEC 62443)
III.I.13+14	28, 29	CLC/TC 47X WG 1	80923	EN 50765	Essential cybersecurity requirements for microprocessors and microcontrollers with security-related functionalities
III.I.15	30	CLC/TC 47X/WG CRA		EN 50767	Essential cybersecurity requirements for application specific integrated circuits (ASIC) and field-programmable gate arrays (FPGA) with security-related functionalities
III.I.16	31	ETSI CYBER-EUSR	DEN/CYBER-EUS-0011	EN 304 631	Essential cybersecurity requirements for smart home general purpose virtual assistants
III.I.17	32	ETSI CYBER-EUSR	DEN/CYBER-EUS-0014	EN 304 632	Essential cybersecurity requirements for smart home products with security functionalities, including smart door locks, security cameras, baby monitoring systems and alarm systems
III.I.18	33	ETSI CYBER-EUSR	DEN/CYBER-EUS-004	EN 304 633	Essential cybersecurity requirements for Internet connected toys covered by Directive 2009/48/EC that have social interactive features (e.g. speaking or filming) or that have location tracking features
III.I.19	34	ETSI CYBER-EUSR	DEN/CYBER-EUS-003	EN 304 634	Essential cybersecurity requirements for personal wearable products to be worn or placed on a human body that have a health monitoring (such as tracking) purpose and to which Regulation (EU) 2017/745 or Regulation (EU) 2017/746 do not apply or personal wearable products that are intended for the use by and for children
III.II.1	35	ETSI CYBER-EUSR	DEN/CYBER-EUS-0016	EN 304 635	Essential cybersecurity requirements for hypervisors and container runtime systems that support virtualised execution of operating systems and similar environments
III.II.2	36a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0020	EN 304 636	Essential cybersecurity requirements for firewalls, intrusion detection and/or prevention systems
III.II.2	36b	CLC/TC 65X WG 3	81649	EN 62443-5	Security Profile for firewalls and intrusion detection and prevention systems (based on IEC 62443)
III.II.3+4	37, 38	CLC/TC 47X WG 2	80924	EN 50766	Cybersecurity requirements for tamper-resistant microprocessors and microcontrollers
IV.1	39	CEN/TC 224 WG 17	002242XX	EN TTTTT	Cybersecurity requirements for Hardware Devices with Security Boxes
IV.2	40	CEN-CLC/JTC 13 WG 6	JT013102	prEN 40000-x-x	Cybersecurity requirements for products with digital elements – Smart Meter Gateway
IV.3	41a	CLC/TC 47X WG 3	80922	EN 50764	Cyber Resilience of EUCC certified platforms of Smart Cards and Similar Devices Including Secure Elements
IV.3	41b	CEN/TC 224 WG 17		prEN 18330	Cybersecurity requirements for smartcards or similar devices, including secure elements – Application layer
		ETSI CYBER-EUSR	DEN/CYBER-EUS-0019	EN 304 642	Cybersecurity Requirements for Network Functions of Telecommunications Systems

Public Inquiry for CEN Horizontal Standards

- PT1 and Vocabulary have ended their public inquiry phase
  - Endorsed by National Bodies
  - Three meetings per week
  - They are discussing chapter 7 from PT3
  - as both were endorsed by NSOs, CEN is hesitating to address major changes
- PT2
  - Has resumed its activities on 2 December
  - They really need contributions
  - It's the only horizontal that will be delivered in 2027
  - Move forward with EN 18031 Baseline
  - Two days of meetings (8h in total/week)
  - Public Inquiry phase is planned for 3 months in May-July 2026
- PT3
  - CEN sent PT3 (40000-1-3) to the NSBs to initiate the ENQ phase at the beginning of December
  - Out for Public inquiry
    - available at NBN – deadline: 9 Feb
    - Deadline at EVS – 28 February
    - Deadline BSI UK – 3 February
    - Deadline ASI – 12 February
    - Deadline UNE – 14 February
  - Still not clear if it will get the presumption of conformity
  - Expected to be published in October 2026
  - Comment resolution will start in March
  - 31 pages submitted by HAS consultants

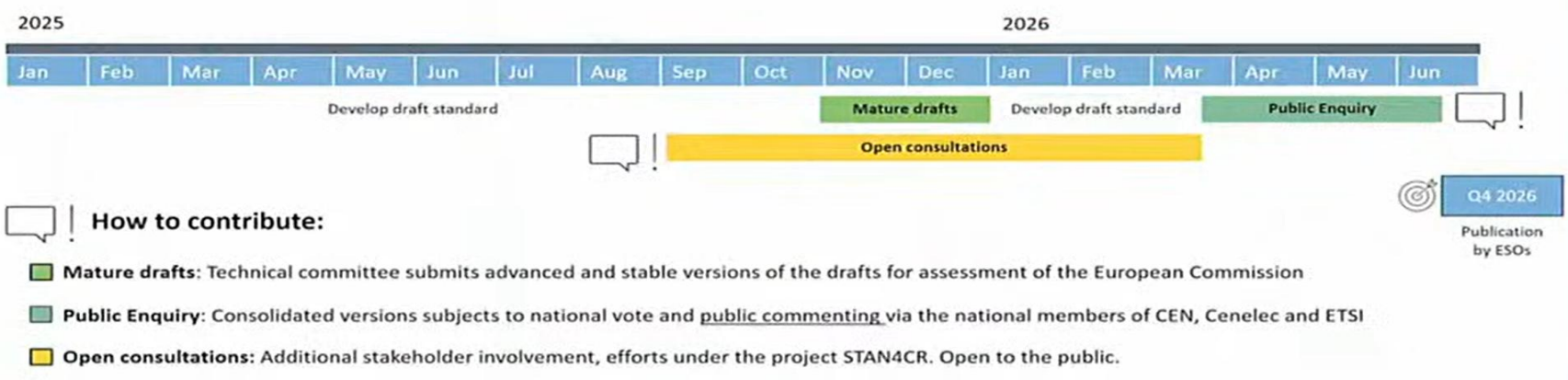
	Oct-25	Nov-25	Dec-25	Jan-26	Feb-26	Mar-26	Apr-26	May-26	Jun-26	Jul-26
Vocabulary 40000-1-1										
PT1 40000-1-2										
PT2 40000-1-4										
PT3 40000-1-3										

Public Inquiry for CEN Vertical Standards

- prEN 50764
  - Smartcards or similar devices, including secure elements
  - Important Class II
  - 3rd party assessment
  - Enquiry stage
- prEN 50765
  - Microprocessors and microcontrollers with security-related functionalities
  - Important class I
  - Enquiry stage
  - Self-assessment
- prEN 50766
  - Tamper-resistant microprocessors and microcontrollers
  - Important Class II
  - 3rd party assessment
  - Enquiry stage
- prEN 50767
  - FPGA/ASICs
  - Important class I
  - HAS assessment
  - Self-assessment

ETSI Open/Public Consultation

- Information website on CRA standards at : www.stan4cra.eu
- Open area for the CRA Vertical draft standards : https://docbox.etsi.org/CYBER/EUSR/Open
- Online consultation platform on working drafts at : https://labs.etsi.org/rep/stan4cra/
- Comments handled by batch on a monthly basis since September 2025 and until the end Q1 2026
- Almost all the drafts were already submitted for HAS assessment
- In January another 28 comments were received
  - SEL4 Foundation
  - ISG NFV
- Escalation on PKI standard (by TC ESI and others)



https://www.youtube.com/watch?v=QRLWcU_Yx18

ETSI (upcoming) deep-dive sessions

These sessions will focus on the following topics:

- Consumer IoT
  - On February 6, between 2PM and 5PM CET
  - Registration link: https://portal.etsi.org/Meetings.aspx#/meeting?MtgId=84021
  - To connect: https://meet.goto.com/etsicybereusr/deep-dive-sessions

As before, this remaining session is open to the general public and are designed to provide detailed insight into the ongoing work by ETSI rapporteurs.
They also offer an excellent opportunity for participants to explore draft standards and share feedback.

Previous Deep Dive sessions

- Routers, Modems and Switches
- Hypervisors and container runtime systems
- Firewalls
- Browsers
- SIEM Systems
- OS
- Antivirus

Standards complexity

Ident	Version	Work Item	Product	Pages	Shalls	Shall/Page
40000-1-1		JT013095	vocabulary	7	0	
40000-1-2		JT013089	cyber resilience	59	118	2.0
40000-1-3		JT013090	vulnerability	51	80	1.6
40000-1-4		JT013091	generic	83	49	0.6
40000-1-5		JT013097	threats	14	0	
EN 304 617	0.0.8	DEN/CYBER-EUS-006	browser	434	957	2.2
EN 304 618	0.0.5	DEN/CYBER-EUS-007	password mgr	120	131	1.1
EN 304 619	0.0.12	DEN/CYBER-EUS-0018	antivirus	140	146	1.0
EN 304 620	0.0.14	DEN/CYBER-EUS-005	VPN	45	58	1.3
EN 304 621	0.0.6	DEN/CYBER-EUS-009	net mgr	56	57	1.0
EN 304 622	0.0.4	DEN/CYBER-EUS-0010	SIEM	37	38	1.0
EN 304 623	0.0.11	DEN/CYBER-EUS-008	boot mgr	87	116	1.3
EN 304 624	0.0.6	DEN/CYBER-EUS-0015	PKI	67	140	2.1
EN 304 625	0.0.11	DEN/CYBER-EUS-0017	net interfaces	73	90	1.2
EN 304 626	0.0.10	DEN/CYBER-EUS-0012	OS	79	99	1.3
EN 304 627	0.0.11	DEN/CYBER-EUS-0013	routers	108	137	1.3
EN 304 631	0.1.0	DEN/CYBER-EUS-0011	virtual assist	53	197	3.7
EN 304 632	0.1.0	DEN/CYBER-EUS-0014	smart home	53	197	3.7
EN 304 633	0.1.0	DEN/CYBER-EUS-004	toys	53	200	3.8
EN 304 634	0.1.0	DEN/CYBER-EUS-003	wearable	37	42	1.1
EN 304 635	0.0.10	DEN/CYBER-EUS-0016	virtualisation	129	397	3.1
EN 304 636	0.0.7	DEN/CYBER-EUS-0020	firewall	103	127	1.2
EN 304 642	0.0.6	DEN/CYBER-EUS-0019	telecom net	58	22	0.4

ETSI CRA Standards Unlocked – EU Tour

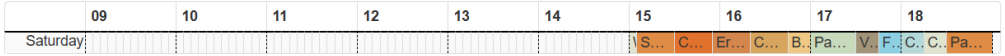
- STAN4CR project is organizing a series of dedicated stakeholder events in partnership with Cyberstand.eu to foster early dialogue and active participation in the development of harmonized CRA standards
- Zagreb, Croatia, 20 January 2026
  - https://www.youtube.com/watch?v=mtSwZ-Ip78E
  - https://www.youtube.com/watch?v=ge6Hg6xjV2g
  - https://cyberstand.eu/events/cra-standards-unlocked-eu-tour-zagreb
- Torino, Italy, 24 February 2026
  - https://cyberstand.eu/events/cra-standards-unlocked-eu-tour-turin
- Barcelona, Spain, 26 March 2026
  - https://cyberstand.eu/events/cra-standards-unlocked-eu-tour-barcelona
- Paris, France, April 2026 (To be confirmed)
- Stockholm, Sweden, 4 May 2026
- La Vallette, Malta, 21 May 2026
- Porto, Portugal, June 2026 (To be confirmed)

Events

FOSDEM 2026

CRA in practice

Room: UA2.114 (Baudoux)
Calendar: iCal, xCal
Chat: Join the conversation!



Read the Call for Papers at https://lists.fosdem.org/pipermail/fosdem/2025q4/003697.html.

Event	Speakers	Start	End
Saturday			
Welcome to the Devroom	Roman Zhukov	15:00	15:05
Software Supply Chain Strategy at Deutsche Bahn	Max Mehl, Henry Sachs	15:05	15:30
CRA-by-Design: Protocol-Embedded Compliance for EV Charging Infrastructure	Achim Friedland	15:30	15:55
Erlang/OTP's journey toward CRA compliance	Kiko Fernandez-Reyes	15:55	16:20
CRA Compliance in Embedded Systems: A Practical Look from the Yocto Project World	Marta Rybczynska	16:20	16:45
Building CRA-Ready Open Source Communities: The Critical Role of Community Managers	Cynthia Lo, Cassie Jiun seo	16:45	17:00
Panel: From Minimum Compliance to Meaningful Stewardship	Madalin Neag	17:00	17:30
VEX - Cutting through the Noise in Software Supply Chain Security	Rao Lakkakula, Georg Kunz	17:30	17:45
First steps towards CRA conformity. A practical introduction to cybersecurity risk management.	Harald Fischer	17:45	18:00
Can security attestations deliver on their promise to simplify due diligence and strengthen open source sustainability?	Tobie Langel	18:00	18:15
CRA-ppy data: We need better open data for CRA compliance	Georg Link, Thomas Steenbergen	18:15	18:30
Panel: Why is the CRA worth a FOSS maintainer's attention?	Roman Zhukov, Philippe Ombredanne	18:30	19:00

Open Source & EU Policy

Room: UA2.118 (Henriot)
Calendar: iCal, xCal
Chat: Join the conversation!

Read the Call for Papers at https://softwarefreedom.net/fosdem-2026-cfp.

Event	Speakers	Start	End
Sunday			
The Euroshack	André Rebentisch	10:10	10:20
The Missing Level: Why EU Open Source Fails Locally	Rasmus Frey	10:20	10:30
Public Procurement for Digital Sovereignty	Sebastian Raible	10:30	11:10
From policy to practice: implementing the EU AI Act for open-source software	Daphne Muller	11:30	11:45
Digital Omnibus: is the EU's tech simplification a Risk or Opportunity for Open Source?	Denise R. S. Almeida	11:45	12:00
The Fediverse and the EU's Digital Services Act: solving the challenges of modern social media?	Jordan Maris	12:00	12:30
HowTheyVote.eu - how we make European Parliament roll-call votes more accessible	Linus Hagemann, Till Prochaska	13:10	13:20
How to engage with policymakers as civil society	Jordan Maris, Sebastian Raible	13:20	14:00
Could Compliance Costs Sustain FOSS? A Theory of Voluntary Attestations	Æva Black	15:20	15:40
Could Compliance Costs Sustain FOSS? A Panel With The Public Sector	Æva Black, Michael Schuster, Greg Wallace, Tommaso Bernabo'	15:40	16:20
Participating in Standardisation around the CRA	Simon Phipps, Jordan Maris	16:20	16:30
Effective standard-setting	Tobie Langel	16:30	17:00

SBOMS and supply chains

Room: UD2.208 (Decroly)
Calendar: iCal, xCal
Chat: Join the conversation!

Read the Call for Papers at https://lists.fosdem.org/pipermail/fosdem/2025q4/003702.html.

Event	Speakers	Start	End
Sunday			
Welcome to the SBOMs and Supply Chains devroom!	Alexios Zavras (zvr), Kate Stewart, Adolfo García Veytia, Thomas Steenbergen	09:00	09:10
The day in a life of a SBOM	Anthony Harrison	09:10	09:30
When One Product Has Three SBOMs: Lessons from Embedded Vulnerability Management	Marta Rybczynska	09:30	10:00
Contextual SBOMs and impact on vulnerability management	Erik Mravec, Martin Jediný	10:00	10:30
Beyond SBOM: Integrating VEX into Open Source Workflows	Piotr P. Karwasz	10:30	11:00
From Passive Data to Active Defense: Supply Chain Policy-as-Code with Conforma	Stefano Pentassuglia	11:00	11:30
CRA-Ready SBOMs: A Practical Blueprint for High-Quality Generation	Viktor Petersson	11:30	12:00
Deutsche Bahn's Approach to Large-Scale SBOM Collection and Use	Max Mehl, Henry Sachs	12:00	12:20
LibreOffice and Collabora Online - how we managed to automate SBOM generation for a large legacy project	Thorsten Behrens	12:40	13:00
Forget SBOMs, use PURLs	Philippe Ombredanne, Steve Springett	13:20	13:40
What is new in SPDX 3.1 which is now a Living Knowledge Graph	Karen Bennet	14:00	14:30
A semantic framework for modelling and analysing supply chains through SBOMs	Giacomo Tenaglia	14:30	15:00
C/C++ Build-time SBOMs with pkgconf	Ariadne Conill	15:30	16:00
Enhancing Swift's Supply Chain Security: Build-time SBOM Generation in Swift Package Manager	Ev Cheng, Sam Khouri	16:00	16:30
Generating SBoMs for BuildStream projects	Abderrahim Kitouni	16:30	17:00

The Linux Foundation Member Summit

- link

2:10pm PST	Securing Open Source – Lessons From the GitHub Security Lab - Xavier René-Corail, GitHub Silverado East
2:50pm PST	Warning Signs: How To Respond Before the OSS Supply Chain Breaks - Brittany Istenes, Fannie Mae Silverado East
4:00pm PST	Securing the Open Source Supply-chain, a Better Approach To Generating SBOMs - Jeff Shapiro, The Linux Foundation & Yue Xiao, William and Mary Silverado East
4:40pm PST	Notes From the Field: Dos and Don'ts of OSS Security at Scale - Adolfo García Veytia, Carabiner Systems Silverado East

Wednesday, February 25

11:30am PST	Security Through Education: Meeting AI, CRA, and Supply Chain Challenges in Software Development - David A. Wheeler, The Linux Foundation Silverado East
1:40pm PST	The First Person Linux Kernel Maintainer Verification Project - Greg Kroah-Hartman, Linux Kernel Maintainer; Daniela Barbosa, LF Decentralized Trust; Glenn Gore, Affinidi Silverado East

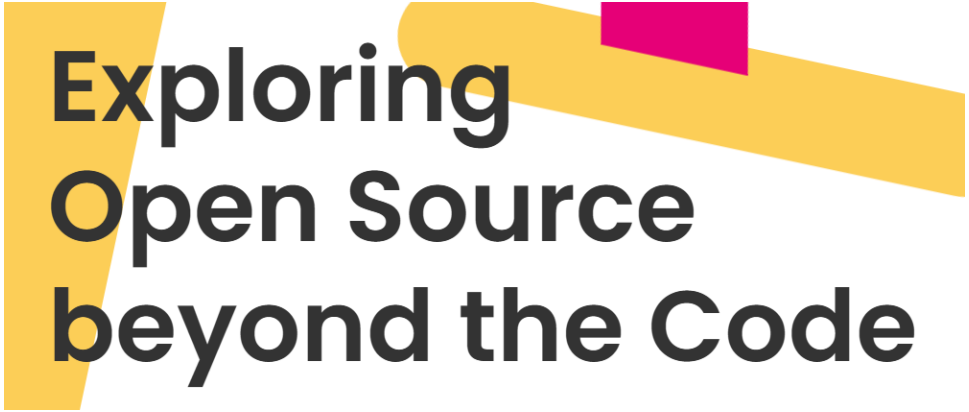
CSC Cybersecurity Standardisation Conference 2026

- 12 March 2026
- Brussels, Marriott Hotel Grand Place / Online
- Registration: http://bit.ly/4qI68Np

TIME	SESSION	TITLE
09:00 – 09:30	Registrations	
09:30 – 09:45	Opening of the conference	
09:45 – 10:45	**Session 1: Challenges and opportunities for the EU standardisation activities** *Where are we in the global standardisation ecosystem and where are we heading?*	• **Panel discussion:** ○ **Jan Ellsberger – ETSI** ○ **Apostolos Malatras – ENISA** ○ **Cinzia Missiroli – CEN and CENELEC** ○ **Raluca Stefanuc – European Commission** • **Presentation:** ***LENS – ENISA cybersecurity standards observatory,*** **Sławomir Górniak,** ENISA
10:45 – 11:15	Coffee break	
11:15 – 12:45	**Session 2: Landscape of legislative proposals and their impact on standardisation** *Cartography of European standardisation, new legal acts and their impact on standardisation*	• **Presentation:** ***Cartography of European standardisation,*** ACN – TBC • **Panel discussion:** ○ **Costas Efthymiou**, Digital Security Authority, Cyprus ○ **Michaela Klopstra,** Accenture. ETSI TC CYBER ○ **Constant Kohler,** Siemens ○ **Annegrit Seyerlein-Klug,** Technische Hochschule Brandenburg ○ **Thomas Stubbings,** Cyber Trust Services
12:45 – 13:45	Lunch break	
13:45 – 15:15	**Session 3: Standards for the Cyber Resilience Act – a gamechanger for European cybersecurity** *Update on the state of affairs, journey towards harmonisation, interplay of CRA with other legislation and its impact on standards*	• **Presentation:** ***CRA harmonized standards assessment – the journey,*** **Camille Dornier,** European Commission • **Panel discussion:** ○ **Roland Atoui, Red Alert Labs** ○ **Sonia Compans, STMicroelectronics** ○ **Camille Dornier, European Commission** ○ **Sandra Feliciano, ETSI TC CYBER EUSR** ○ TBC
15:15 – 15:45	Tea break	
15:45 – 16:45	**Session 4: Way forward for the EU standardisation** *Interactive discussion on the future of standardisation in Europe*	• **Presentation:** ***ENISA work on certification schemes and need for standards,*** **Eric Vetillard,** ENISA • **Panel discussion:** ○ **Martin Chatel,** ETSI ○ **Omar Dhaher,** DIGITALEUROPE ○ **Walter Fumy,** CEN-CENELEC JTC13 ○ **Rob van der Veer,** OWASP ○ TBC
16:45 – 17:00	Summary and closing remarks	

FOSS Backstage

- 16-17 March
- Berlin
- https://26.foss-backstage.de/
- https://26.foss-backstage.de/schedule/



Open Source SecurityCon

- 23 March
- Amsterdam
- RAI
- https://events.linuxfoundation.org/kubecon-cloudnativecon-europe/co-located-events/open-source-securitycon/

OPEN SOURCE SecurityCon EUROPE

Monday, March 23

09:00 CET	Open Source SecurityCon | Welcome + Opening Remarks HALL 11
09:10 CET	From Mild To Wild: How Hot Can Your SLSA Be? - Andrew McNamara, Red Hat & Adolfo Garcia Veytia, Carabiner Systems HALL 11
09:40 CET	Lightning Talk: A Case Study in Cross-Ecosystem Security Response - Lori Lorusso, Rust Foundation HALL 11
10:20 CET	AM Break 2
10:40 CET	Trust, Tampering, and Transparency: What History Can Teach Us About Open Source Security - Lisa Tagliaferri, Chainguard HALL 11
11:15 CET	Upstream Collaboration for the Win (of the CRA)! - Georg Kunz & Jan Melen, Ericsson Software Technology HALL 11
11:50 CET	Panel: It's Not If, It's When - Practical Preparation for the Next Software Supply Chain Attack - Hannah Foxwell & Justin Cormack, Independent; Sal Kimmich, GadflyAI; Erika Heidi, Chainguard; Josh Bressers, Anchore HALL 11
12:25 CET	Lunch Break 2
13:30 CET	Zero Privilege Architecture - 3 Years Onward - Thijs Ebbers & Tadeo Sanchez, ING HALL 11
14:05 CET	Quantum Proofing Sigstore: A Tale of Three Approaches - Kevin Conner & Firas Ghanmi, Red Hat HALL 11
14:40 CET	Tarmageddon: One Bug, Four Forks, and a Disclosure Scavenger Hunt - Marina Moore & Alex Zenla, Edera HALL 11
15:05 CET	PM Break 1
15:20 CET	Secure Your MCP Servers With OAuth, JWT, SPIFFE and More - Lin Sun, Solo.io & Yi Yang, IBM HALL 11
15:55 CET	Simplifying Global Compliance for CNCF Projects With the OpenSSF OSPS Baseline - Madalin Neag, OpenSSF HALL 11
16:30 CET	Signals To Stages: An Effect-Based Maturity Model for Secure Software Delivery - Brandt Keller, Defense Unicorns HALL 11
17:00 CET	Lightning Talk: Your Most Privileged User Isn't Human: The Agent Security Blindspot - Atulpriya Sharma, Improving HALL 11
17:15 CET	Lightning Talk: A Supply Chain Security View of OpenSearch - Ram Iyengar, Linux Foundation HALL 11
17:25 CET	Open Source SecurityCon | Closing Remarks HALL 11

EU Cyber Acts Conference

A European Framework for Global Developers: Building a Bridge to Cyber Compliance

09:00-17:00 SPECIAL FOCUS DAY

The EU Cyber Certification Series Includes:

Presenting Sponsor: **GlobalPlatform**.
Prepare now for the requirements of the EU Cyber Resilience Act (CRA).

Presenting Sponsor: **Jones Day**.
Cybersecurity Policy Developments Shaping the EU and Global Digital Landscape

https://eucyberact.org/conference-agenda-2026/

Complementary standards

ITU-T SG17

- "Framework for Cyber Resilience Testing and Assurance"
  - To assess software products resilience to threats and the establishment of assurance principles and claims document
  - Its relevance to connected products will help ensure confidence that they are safeguarded against malicious activity originating from public domains
  - This document aligns assurance principles with claims, outlining the scope of the assurance activities and specifying the level of information needed for evaluation.
- Cyber Security Reference Architectures, Methodologies, Models and Strategies (CRAMMS) Roadmap
  - TR
  - Outlines the context, key drivers, and structured approach for a future-proof ITU-T SG17 standardization strategy and roadmap
  - Examines challenges, opportunities, and forces of change in the global digital ecosystem to inform strategic directions
  - Introduces a holistic framework to classify and guide development of standards supporting secure, resilient, and trustworthy digital systems

TC CYBER SSDIF

- Translation of NIST SSDF tasks into an ETSI standard that could be easier to be referenced
- Under the remote consensus until the end of this week
- https://portal.etsi.org/webapp/WorkProgram/Report_WorkItem.asp?WKI_ID=75450

Details of 'DTS/CYBER-00178' Work Item

ETSI	Work Item Reference	ETSI Doc. Number	STF	Technical Body in Charge	Standard Not Ready For Download
	DTS/CYBER-00178	TS 104 219		CYBER	
	Current Status (Click to View Full Schedule)	Latest Version	Cover Date	Standstill	Creation Date
	Final draft (2026-01-14)	0.0.7 Draft		View Standstill Information	2025-08-22
	Rapporteur	Technical Officer		Harmonised Standard	
	Tony Rutkowski	Kim Nordström		No	

Title	Cyber Security (CYBER); Software Security Development and Implementation Framework SSDIF
Scope and Field of Application	The proposed work item will provide specific usable guidance differentiated by available resources for three parties in the software ecosystem toward implementing evaluable, effective software security. For end user customers, it will specify what to ask for and what steps to take. For software development organizations, it will specify what to do. For governmental or industry bodies, it will define the specifics to demonstrate that secure by design practices have been followed.
Supporting Organizations	Cadzow Communications, SBS aisbl, NCSC, CIS, Palo Alto Networks

Have your say

Public Consultation on European Open Digital Ecosystem Strategy

- https://ec.europa.eu/info/law/better-regulation/have-your-say/initiatives/16213-European-Open-Digital-Ecosystems_en
- The European Open Digital Ecosystem Strategy will set out:
  - a strategic approach to the open source sector in the EU that addresses the importance of open source as a crucial contribution to EU technological sovereignty, security and competitiveness
  - a strategic and operational framework to strengthen the use, development and reuse of open digital assets within the Commission, building on the results achieved under the 2020-2023 Commission Open Source Software Strategy.
- Deadline – 3 February
- OpenSSF has contributed to the LFEU answer

European Standardisation Panel Survey

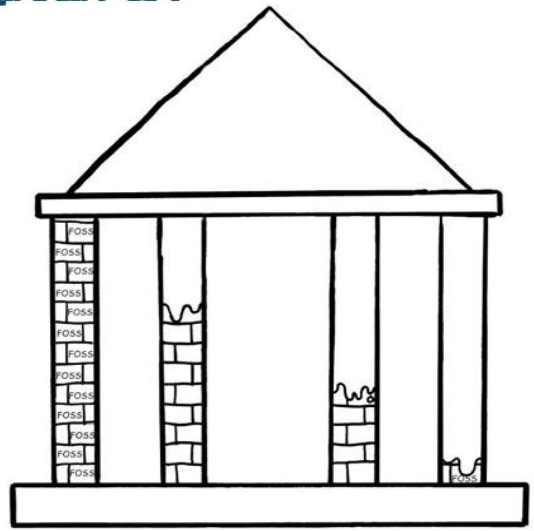
- Previous version of EU Standardisation Panel Survey: https://op.europa.eu/en/publication-detail/-/publication/d5c4f1a7-e75e-11ee-9ea8-01aa75ed71a1/language-en
- If you want to contribute to a common answer, you can add your views here: https://docs.google.com/document/d/1HXHV8BkHnx4SPThYdK_8Kpbuol2Ay8SB3sgDo0z7LbA/edit?tab=t.0#heading=h.tfjssb1lbwkc
- The Commission has launched the second edition of the European Standardisation Panel survey to gather input from the industry and other stakeholders on their standardisation needs, to boost innovation and European competitiveness
- OpenSSF, JDFP and LFEU submitted correlated answers

ENISA’s calls for feedback

- **Advancing Software Supply Chain Security together**
  - draft report
  - You may provide your feedback by **23 January 2026 at 23:59 CET** by taking part in the survey
  - We created a document to collect your feedback
- **ENISA Technical Advisory for Secure Use of Package Managers**
  - draft document
  - You may take part in the consultation for the Technical Advisory **by 23 January 2026, 23:59 CET** through the following link
  - We created a document to collect your feedback
- OpenSSF has submitted answers to both of them
  - Thank you to Olle and Tanya for their inputs

AOB

Thanks, and a promise: A better future!



You

- Pour your heart into developing FOSS
- Sacrifice your time for the common good
- Create the digital building blocks our society depends on
- Help to build our future

We

- Appreciate this gift you are giving to the whole society
- Want to say THANK YOU!
- Promise the CRA will help you
- Know that words are nice, but practical help/support is better

ECCC publishes new call for proposals under Digital Europe Programme

- https://cybersecurity-centre.europa.eu/news/eccc-publishes-new-call-proposals-under-digital-europe-programme-2025-10-22_en
- The call Cyber 09 focuses on critical areas of cybersecurity deployment and covers the following topics:
  - Cybersecure tools, technologies and services relying on AI
  - Uptake of innovative cybersecurity solutions for SMEs
  - Coordinated preparedness testing and other preparedness actions
  - Regional Cable Hubs

Funding for SMEs

- The SECURE project (secure4sme.eu), funded under the Digital Europe Programme, launched a first round of financial support measures to help small businesses achieve compliance with new cybersecurity requirements for their hardware and software products.

- This will allow micro, small and medium enterprises (MSMEs) to request co-funding to strengthen the cybersecurity of their hardware and software products to ensure compliance with the CRA.

- As part of the first round of financial support measures offered by the SECURE project, MSMEs may request co-funding for certain activities with a **maximum of EUR 30.000**. Requests can be submitted from 28 January to 29 March 2026.

1st Call Total Budget	€ 5 million
Funding per grant	Up to € 30,000
Target applicant	Micro, small and medium-sized enterprises (MSMEs)
Co-financing	50%
First call	28 January 2026 - 29 March 2026

SECURE
Cyber Resilience for SMEs

ETSI TS 104 008

- Methods for Testing & Specification (MTS); Continuous Auditing Based Conformity Assessment for AI-enabled systems
- Framework for Continuous Auditing-Based Conformity Assessment (CABCA)
- This framework helps organisations ensure their AI systems remain compliant with regulatory and technical requirements throughout their entire operational lifecycle
- ETSI TS 104 008 addresses this challenge by establishing a structured methodology for automated, ongoing conformity assessment, supporting the post-market monitoring obligations of the EU Artificial Intelligence Act.

Standards are key to agentic AI security and digital IDs

- https://www.itu.int/hub/2026/01/why-standards-are-key-to-agentic-ai-security-and-digital-ids/
- In the process of establishing a new working group, Question 16/17: AI Security,
  - merging its Questions 3/17 and 10/17 working on digital identity for agentic AI.
- The critical 3 connected workshops coming:
  - 30-31st of March SG17 Workshop in Geneva during the 1st Content Week **Trustable and Interoperable Digital Identities for Human and Agentic AI**
  - (provisional) 3rd of June SG17 Workshop in Geneva during 5th SG17 Plenary Meeting - **Globally interoperable digital identity**
  - (provisional) 10th of July SG17 Workshop in Geneva during AI for Good - **Designing the Trust Management for Agentic AI**

EU and Japan hold 7th Cyber Dialogue in Brussels

- Cyber: European Union and Japan hold 7th Cyber Dialogue in Brussels
- Further **cooperation on synergies** between the CRAand the Japanese JC-STAR labelling scheme to enhance the resilience of our markets

+

- UK-Japan strategic cyber partnership announced on 31 January
  - Share cyber threat intelligence
  - Share best practices
  - Build a growth and innovation ecosystem by cooperation

ECMA Contributing.yaml specification

- https://github.com/Ecma-TC54/tg4
- ECMA TC54 TG4
- https://tc54.org/contributing-yaml/
- https://ecma-international.org/task-groups/tc54-tg4/
- Ecma TC54-TG4 is chartered with the standardization of Contributing JSON, an open contributions specification to enable the structured and machine-readable communication of an open source community's or project's state, needs, and support intentions. This includes codifying maintainers' support levels, signalling calls for assistance, identifying abandonment or handoff status, and improving visibility into whether a project is viable for commercial or long-term use. The Contributing JSON specification aims to support software supply chain risk assessment, organisational investment decisions, and community sustainability efforts.

Global Platform SESIP

- The Security Evaluation Standard for IoT Platforms (SESIP)
- https://globalplatform.org/sesip/
- SESIP has been adopted by CEN and CENELEC as a European Standard (EN 17927)
- A methodology that reduces the cost, complexity and effort of security evaluation and certification
- The methodology maps to other standards and requirements from bodies including ETSI, ISO/IEC and NIST, which demonstrates a risk-based design approach and helps lower barriers to entry

Preserving Open Source Sustainability While Advancing Cybersecurity Compliance

- https://openssf.org/blog/2026/01/21/preserving-open-source-sustainability-while-advancing-cybersecurity-compliance/

SBOMs in the Era of the CRA: Toward a Unified and Actionable Framework

- https://openssf.org/blog/2025/10/22/sboms-in-the-era-of-the-cra-toward-a-unified-and-actionable-framework/

Improving Risk Management Decisions with SBOM Data: A New Whitepaper from the OpenSSF SBOM Everywhere SIG

- https://openssf.org/blog/2025/09/18/improving-risk-management-decisions-with-sbom-data-a-new-whitepaper-from-the-openssf-sbom-everywhere-sig/

Thank you very much

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Back-up slides

CRA Standardization request

EUROPEAN
COMMISSION

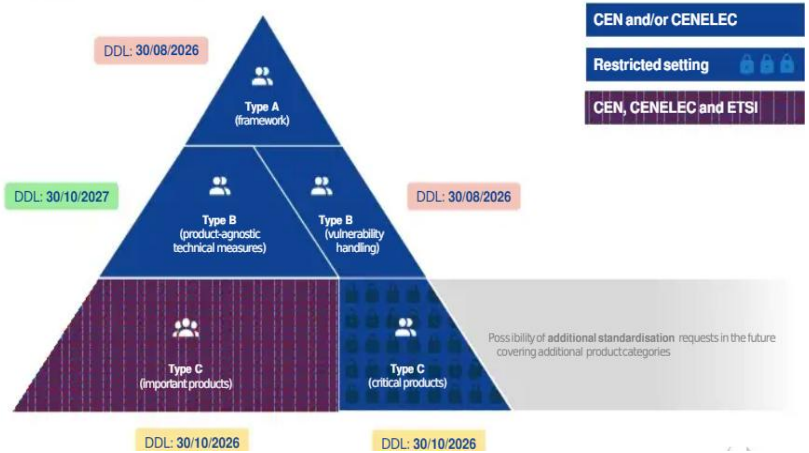
Brussels, 3.2.2025
C(2025) 618 final

COMMISSION IMPLEMENTING DECISION

of 3.2.2025

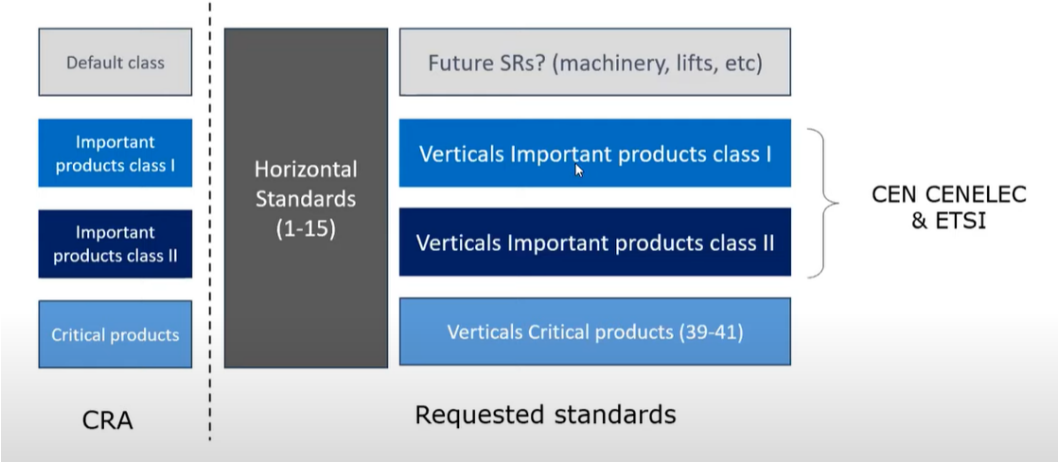
on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

https://ec.europa.eu/transparency/documents-register/detail?ref=C(2025)618&lang=en
https://cyberstand.eu/sites/default/files/2025-02/Filipe%20Slides%20CRA_implementation_Feb-2025.pdf



Horizontal standards (1-15)	Vertical standards (16-41)
• Risk-based approach (CRA Annex I) • Essential Requirements (CRA Annex I part 1) • Vulnerability Handling (CRA Annex I part 2)	• Important products class 1 (CRA Annex III) • Important products class 2 (CRA Annex III) • Critical products (CRA Annex IV)

CRA Standardization request

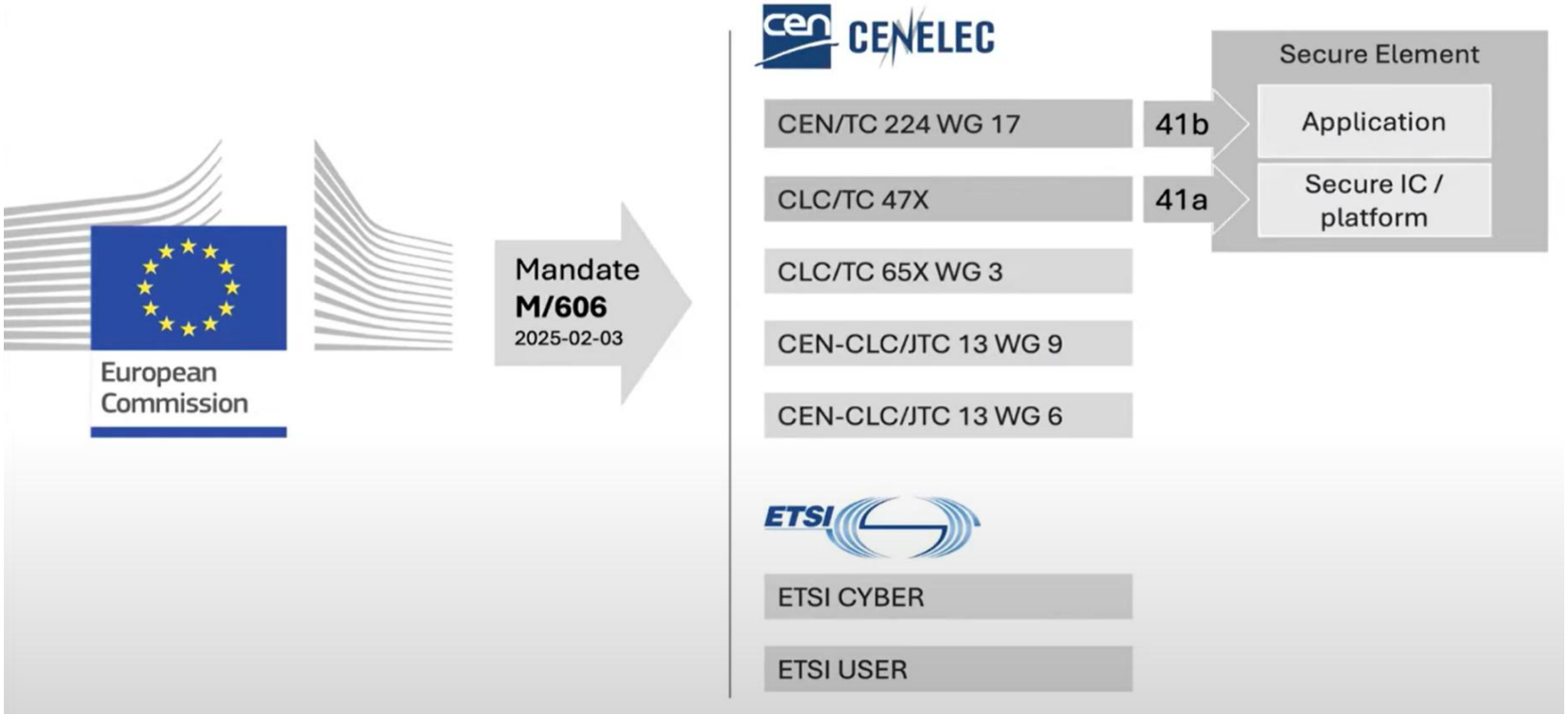


41 topics

3 ‘types’ of deliverables:

Category “A”: horizontal framework	Category “B”: product-agnostic technical measures & vulnerability handling	Category “C”: Important and critical products CRA Standardization Request 9 April 2025 36
• Only CEN and CENELEC • Topic #1 (JTC 13 WG9) • deadline 2026-08-30	• Only CEN and CENELEC • Topic #2-15 (JTC 13 WG9) • Deadline 2027-10-30 (except for line 15 - vulnerability handling - 2026-08-30)	• Topic #16-38: CEN, CENELEC and ETSI • deadline 2026-10-30 • Topic #39-41:CEN and CENELEC • Critical products

CRA Standardization request



https://www.youtube.com/watch?v=_C9HGqBT6qw

A section of the CEN, CENELEC and ETSI WP

Version: V1
Date: 2025-04-02

CEN, CENELEC and ETSI Work Programme
M/604- Cyber Resilience Act

M/606	Technical Committee(s)		M/606 - Planning for standard development						
Topics M606 - Annex I	TC ref.	TC title	In collaboration with	Work Item	Standard reference	Standard title	Last realized stage	Deadline for adoption	Comment
Line 1: European standard(s) on designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks									
1	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013089	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements Principles for cyber resilience	10.99 - NWI - New Work Item adopted	2026/08/30	
Lines 2-14 - European standard(s) CRA essential requirements									
2 to 14	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013091	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements – Generic Security Requirements	10.99 - NWI - New Work Item adopted	2027/10/30	
Line 15: European standard(s) on vulnerability handling for products with digital elements									
15	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013090	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements – Vulnerability handling	10.99 - NWI - New Work Item adopted	2026/08/30	
Line 16: European standard(s) on essential cybersecurity requirements for identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers									
16	CEN/TC 224 WG 17	Personal identification and related personal devices with secure element, systems, operations and privacy in a multi sectorial environment	CEN/TC 224 WG 17 (including expertise from WG 18,19 and 20) TC ESI	002242XX	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers : criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)	TC decision taken	2026/10/30	
Line 17: European standard(s) on essential cybersecurity requirements for standalone and embedded browsers									
17a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 617-1*	European standard(s) on essential cybersecurity requirements for embedded browsers	PWI - Proposed Work Item created	2026/10/30	
17b	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 617-2*	European standard(s) on essential cybersecurity requirements for standalone browsers	PWI - Proposed Work Item created	2026/10/30	
Line 18: European standard(s) on essential cybersecurity requirements for password managers									
18	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 618*	European standard(s) on essential cybersecurity requirements for password managers	PWI - Proposed Work Item created	2026/10/30	
Line 19: European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software									
19	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 619*	European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software	PWI - Proposed Work Item created	2026/10/30	
Line 20: European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)									
20a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9 CLC/TC 65X WG3 mode 2	*(Will be be defined after the adoption of the Work Item)*	*EN 304 620*	European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)	PWI - Proposed Work Item created	2026/10/30	
20b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	ETSI TC Cyber EUSR Mode 2	81652	*EN 62443-5-XX (Will be be defined after the activation of the Work Item)*	Security Profile for products with digital elements with the function of virtual private network (VPN)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 21: European standard(s) on essential cybersecurity requirements for network management systems									
21a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9 CLC/TC 65X WG3 mode 2	*(Will be be defined after the adoption of the Work Item)*	*EN 304 621*	European standard(s) on essential cybersecurity requirements for network management systems	PWI - Proposed Work Item created	2026/10/30	
21b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	ETSI TC Cyber EUSR Mode 2	81650	*EN 62443-5-XX (Will be be defined after the activation of the Work Item)*	Security Profile for network management systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	

Not complete

https://www.cencenelec.eu/media/CEN-CENELEC/News/Newsletters/2025/m_606_work_programme_final.pdf

CEN/CENELEC Work Programme

Project Team 1	Project team 2	Project team 3

• **Cybersecurity requirements for products with digital elements – Principles for cyber resilience**
• WI number – JT013089
• CRA requirement Annex I, Part I, 1
• M/606 item 1, 30/08/2026
• Does not (directly) provide a presumption of conformity.
• Addressing the process activities for security risk management during the total product life cycle.
• Activities are described as:
  • Expected inputs
  • Requirement
  • Expected outputs
  • Assessment criteria
• As a horizontal framework standard, it will not mandate any specific methodologies.
	• **Cybersecurity requirements for products with digital elements – Generic security requirements**
	• WI number : JT013091
	• CRA requirement Annex I, Part I, 2
	• M/606 items 2-14, 30/10/2027
	• Does not provide a presumption of conformity.
	• Addressing the essential product requirements.
	• Provides a library of security controls with their objectives and more technical assessment criteria.
	• Provides a mapping of the essential requirements to these security controls.
	• Builds upon the EN 18031:2024 series, augmented with additional security controls.
		• **Cybersecurity requirements for products with digital elements – Vulnerability handling**
		• WI number : JT013090
		• CRA requirement Annex I, Part II
		• M/606 item 15, 30/08/2026
		• The only horizontal standard of the three that hopefully might be suited for citation to provide a partial presumption of conformity.
		• Addressing the process activities for vulnerability handling.
		• Perceived as a horizontal standard that the verticals should be able to normatively reference with no or minimal adoptions.
		• Strong normative dependency on the SOTA standards EN ISO/IEC 30111 and 29147.